standpoint. In the next section we'll look in detail at these tokens and how they work.

25.2 Understanding bearer token authentication

In this section you'll learn about bearer tokens: what they are, how they can be used for security with APIs, and the common JWT format for tokens. You'll learn about some of the limitations of the tokens, approaches to work around these, and some common concepts such as audiences and scopes.

The name *bearer token* consists of two parts that describe its use:

- *Token*—A *security token* is a string that provides access to a protected resource.
- *Bearer*—A *bearer* token is one in which anyone who has the token (the bearer) can use it like anyone else. You don't need to prove that you were the one who received the token originally or have access to any additional key. You can think of a bearer token as being a bit like money: if it's in your possession, you can spend it!

If the second point makes you a little uneasy, that's good. You should think of bearer tokens as being a lot like passwords: you must protect them at all costs! You should avoid including bearer tokens in URL query strings, for example, as these may be automatically logged, exposing the token accidentally.